



CIS*6520 - DIGITAL FORENSICS & INCIDENT RESPONSE

NETWORK FORENSIC INVESTIGATION REPORT

CASE: GTTA-DFIR-2026-002

Greater Toronto Transit Authority
Webshell Exploitation & Data Exfiltration — March 14, 2026

Field	Detail
Case Name	GTТА Webshell Exploitation and Data Exfiltration — March 14, 2026
Case ID	GTТА-DFIR-2026-002
Related Case	GTТА-DFIR-2025-001 (December 31, 2025 Perimeter Intrusion)
Evidence File	2026-03-14 – perimeter.pcap
Date of Report	March 28, 2026
Student Number	1405802
Name of Student (Examiner)	Alfred Amoah

1. Executive Summary

On March 14, 2026, the network traffic captured at the Greater Toronto Transit Authority (GTTA) internal network segment identified the active exploitation of a PHP webshell that was previously planted on an internal Ubuntu server with an IP address 192.168.56.102. The 171-packet capture represents a focused, deliberate post-compromise activity launched by an attacker who was operating from an IP address 192.168.56.1, identified as a Kali Linux machine within the GTTA internal network.

We can clearly establish the connection between this attack and that of the with reference (Case GTTA-DFIR-2025-001), that occurred on December 31, 2025. The webshell identified in this capture `badshell.php`, which is the publicly known **Simple PHP Backdoor** by DK was planted on the GTTA server during the confirmed **CVE-2024-4577** exploitation documented in the prior investigation. Strategically, the attacker returned approximately ten weeks after the initial compromise to conduct hands-on post-exploitation activity using this persistent backdoor approach.

The analysis further revealed that the attacker executed four distinct commands against the server via the webshell; **whoami** (privilege identification), **finger** (user enumeration), **ls** (directory listing), and **cat secret.txt** (file exfiltration). All these commands were executed successfully and returned responses to the attacker. The directory listing revealed a second hidden backdoor `.reverse_shell.php` indicating a more sophisticated and deeply embedded compromise than the initial webshell alone suggests. The final command successfully exfiltrated the contents of a file explicitly marked as sensitive, constituting a confirmed data breach.

BUSINESS IMPACT: This capture confirms an active, confirmed data exfiltration event against GTTA internal infrastructure. An attacker with an established foothold inside the GTTA network successfully read and exfiltrated sensitive file contents from a compromised internal server. The presence of a hidden reverse shell backdoor indicates the attacker has deeper persistence capabilities beyond the known webshell. Immediate containment and full forensic examination of all GTTA internal systems is urgently required.

2. Scope and Objectives

2.1 Investigation Objectives

This investigation was conducted with the following objectives:

- Identify and document all activity captured in the 2026-03-14 perimeter.pcap evidence file
- Determine the nature and sequence of commands executed via the identified webshell
- Recover and document the server's response to each executed command
- Establish the linkage between this incident and Case GTTA-DFIR-2025-001
- Identify all persistence mechanisms present on the compromised server
- Determine the scope and content of data exfiltrated from the GTTA server
- Provide evidence-based remediation recommendations

2.2 Scope

The scope of this investigation is to analyse a single **PCAP file 2026-03-14** perimeter.pcap containing 171 packets of internal network traffic between two hosts on the **192.168.56.0/24** subnet. All traffic in the capture was between **192.168.56.1** (attacker's server) and **192.168.56.102** (victim's server). The investigation also covers the complete session from initial connection through to confirmed data exfiltration.

Scope Item	Detail
Evidence File	2026-03-14 – perimeter.pcap
Total Packets	171
Capture Duration	Approximately 95 seconds
Attacker IP	192.168.56.1 (Kali Linux — internal network)
Victim IP	192.168.56.102 (Ubuntu — Apache/2.4.7)
Network Segment	192.168.56.0/24 (Internal GTTA network)
Protocols Analysed	TCP, HTTP, ARP, BOOTP/DHCP
Related Case	GTТА-DFIR-2025-001

3. Methodology

The investigation followed the same structured network forensics methodology applied in Case ID; **GTТА-DFIR-2025-001**, which adapted for the smaller and more focused nature of this capture.

3.1 Tools Used

Below are the tools used for this indepth investigation;

Tool	Version	Purpose
Wireshark	1.10.5	Primary PCAP analysis, stream reconstruction, packet dissection
Wireshark Uncompressed Entity Body	Built-in	Decompression of gzip-encoded HTTP response bodies to recover plaintext command outputs

3.2 Analysis Process

- **Phase 1 (Initial Triage):** Protocol Hierarchy Statistics and HTTP Requests analysis to establish the nature of the capture
- **Phase 2 (HTTP Traffic Analysis):** Export and analysis of all 32 HTTP packets to identify the attack sequence and command progression

- **Phase 3 (Stream Analysis):** Follow TCP Stream for all 9 TCP streams (streams 0–8) to reconstruct the complete attacker-server conversation
- **Phase 4 (Response Decompression):** Examination of Uncompressed Entity Body for packets #30, #65, #93, #125, and #163 to recover plaintext webshell command outputs from gzip-compressed HTTP responses
- **Phase 5 (Cross-Reference):** Correlation of findings with Case GTTA-DFIR-2025-001 to establish the attack chain across both captures

3.3 Wireshark Configuration

HTTP preferences were confirmed as per Case GTTA-DFIR-2025-001; Reassemble HTTP headers and bodies spanning multiple TCP segments, Reassemble chunked transfer-coded bodies, and Uncompress entity bodies. The Uncompressed Entity Body tab in the packet details panel was used to view plaintext content of gzip-compressed server responses, which was essential for recovering actual command outputs from the webshell.

4. Evidence Collection and Preservation

4.1 Evidence Source

Attribute	Value
Evidence Type	Network packet capture (PCAP)
File Name	2026-03-14 – perimeter.pcap
Total Packets	171
Total Bytes Captured	27,622 bytes
Capture Duration	~95 seconds
Capture Point	GTТА internal network segment sensor
Analysis Environment	University of Guelph REM Workstation (Z: drive)
Related Evidence	2025-12-31 – perimeter.pcap (Case GTТА-DFIR-2025-001)

4.2 Chain of Custody

The PCAP file was provided by the course instructor as part of the CIS*6520 assignment and accessed via the university network share at **Z:\DFIR PROJECTS**. The file was opened in read-only mode within Wireshark. No files were extracted from the PCAP. No modifications were made to the original evidence file. All analysis was performed through Wireshark's built-in dissection and stream reconstruction capabilities. The integrity of the original PCAP was preserved throughout the investigation.

5. Key Findings and Analysis

5.1 Protocol Distribution Overview

Protocol Hierarchy Statistics analysis of the 171-packet capture revealed a highly focused traffic profile consistent with a targeted post-exploitation session rather than opportunistic scanning:

Protocol	% Packets	Packets	Significance
TCP	97.08%	166	Dominant transport — all activity over TCP
HTTP	18.71%	32	Primary attack vector — all webshell commands
Line-based text data	11.11%	19	Plaintext HTML response bodies — command outputs
Malformed Packet	0.58%	1	Single malformed packet — initial syntax error
UDP/BOOTP	1.17%	2	DHCP — host network initialisation
ARP	1.75%	3	Address resolution — internal network mapping

The absence of ICS protocols, mass scanning traffic, and external IP addresses distinguishes this capture entirely from PCAP 1. This is a targeted internal session with a single attacker communicating with a single victim server over a 95-second window.

5.2 Network Participants

Host	IP Address	Role	Evidence
Attacker Machine	192.168.56.1	Kali Linux (attack platform)	Visible in VMware Workstation library during analysis; source of all requests
Victim Server	192.168.56.102	Ubuntu — Apache/2.4.7, PHP/5.5.9	Server header confirmed in every HTTP response; MAC 08:00:27:be:9f:30 (VirtualBox NIC)

Both hosts reside on the **192.168.56.0/24** subnet, a **VirtualBox/VMware** host-only network segment. This confirms the attacker has already achieved internal network access, consistent with the lateral movement capability established via the CVE-2024-4577 compromise in **PCAP 1**. The victim server MAC address prefix 08:00:27 is assigned to Oracle VirtualBox, confirming this is a virtualised Ubuntu server.

The server's reported date in HTTP response headers Fri, 22 Apr 2016 indicates a severely misconfigured or deliberately outdated system clock. This is consistent with a legacy VM image that has not been maintained. The software versions confirm this; Apache/2.4.7 was released November 2013 and PHP/5.5.9 reached end-of-life in July 2016. Both recorded numerous known critical vulnerabilities.

5.3 Complete Attack Sequence

The entire attack session lasted approximately 95 seconds from first packet to last. The following documents every HTTP interaction with full request and response detail.

5.3.1 Phase 1 — Server Reconnaissance (Packets #1–19, Time: 0.000–5.018s)

The attacker established a TCP connection to port 80 on 192.168.56.102 and issued an initial HTTP GET request to enumerate the server:

```
REQUEST (Packet #5): GET / HTTP/1.1Host: 192.168.56.102User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_4) AppleWebKit/601.5.17 (KHTML, like Gecko) Version/9.1 Safari/601.5.17Accept-Encoding: gzip, deflateCache-Control: max-age=0RESPONSE (Packet #9):HTTP/1.1 200 OKDate: Fri, 22 Apr 2016 02:55:07 GMTServer: Apache/2.4.7 (Ubuntu)Content-Encoding: gzipContent-Type: text/html
```

The server then responded with its default Ubuntu Apache landing page (confirmed by the subsequent request for /icons/ubuntu-logo.png). This initial browse confirmed the server's operating system, web server version, and that the service was running. The User-Agent string presents as Safari on Mac OS X 10.11.4 either the attacker's actual browser or a deliberate spoofed user agent to blend in with normal traffic.

5.3.2 Phase 2 — Webshell Confirmation (Packets #23–41, Time: 26.534s)

After a 26-second pause following initial reconnaissance, the attacker directly accessed the planted webshell:

```
REQUEST (Packet #27): GET /badshell.php HTTP/1.1Host: 192.168.56.102RESPONSE (Packet #30):HTTP/1.1 200 OKServer: Apache/2.4.7 (Ubuntu)X-Powered-By: PHP/5.5.9-1ubuntu4.14Content-Encoding: gzipContent-Length: 150UNCOMPRESSED BODY:<!-- Simple PHP backdoor by DK (http://michaeldaw.org) -->Usage: http://target.com/simple-backdoor.php?cmd=cat+/etc/passwd
```

The server returned HTTP 200 OK confirming the webshell was present and functional. The uncompressed response body revealed the webshell's identity: the Simple PHP Backdoor by DK, a publicly available PHP webshell first published at michaeldaw.org in 2006. This webshell accepts operating system commands via the cmd GET parameter and returns their output wrapped in HTML pre tags. The X-Powered-By header confirms PHP/5.5.9-1ubuntu4.14 an end-of-life PHP version with multiple known remote code execution vulnerabilities.

5.3.3 Phase 3 — Privilege Identification (Packets #42–89, Time: 45.124–63.744s)

The attacker attempted to determine the privilege level of the webshell using the whoami command. The first attempt contained a syntax error:

```
ATTEMPT 1 — Syntax Error (Packet #46, Time: 45.124s): GET /badshell.php?/cmd=whoami HTTP/1.1Server Response: HTTP/1.1 200 OK (Content-Length: 150)Result: Webshell page returned without command output — incorrect parameter syntax (/cmd instead of ?cmd)ATTEMPT 2 — Correct Syntax (Packet #62, Time: 54.512s):GET /badshell.php?cmd=whoami HTTP/1.1RESPONSE (Packet #65):HTTP/1.1 200 OKX-Powered-By: PHP/5.5.9-1ubuntu4.14Content-Length: 97UNCOMPRESSED BODY:<!-- Simple PHP backdoor by DK (http://michaeldaw.org) --><pre>www-data</pre>
```

The corrected command returned the username www-data the default Apache web server service account on Ubuntu/Debian systems. This confirms the webshell is executing with Apache process privileges. While www-data is not root, it has read access to all web-served files, write access to web directories, and the ability to execute system commands within the constraints of the Apache process. The attacker repeated the whoami command at packet #78 (Time: 60.397s), receiving the same www-data response, consistent with manual verification of the output.

5.3.4 Phase 4 — User Enumeration (Packets #86–121, Time: 63.745–78.141s)

The attacker executed the finger command to enumerate users currently logged into the system:

```
REQUEST (Packet #90, Time: 63.745s): GET /badshell.php?cmd=finger HTTP/1.1RESPONSE (Packet #93):HTTP/1.1 200 OKContent-Length: 181UNCOMPRESSED BODY:<!-- Simple PHP backdoor by DK (http://michaeldaw.org) --><pre>Login    Name    Tty    Idle Login Time    Office
Office Phoneubuntu    ubuntu pts/0    Apr 5 22:50 (:0)</pre>
```

The finger command output revealed that the legitimate system administrator account ubuntu was actively logged in via pts/0 (a pseudo-terminal session) with a graphical display session at :0. The login time of Apr 5 22:50 indicates the ubuntu user had been logged in for an extended period prior to the attacker's session. This is forensically significant as the attacker was conducting post-exploitation activity on a system where the legitimate owner was actively present, increasing the risk of detection but also indicating the attacker was operating with confidence in their persistence. The command was repeated at packet #112 (Time: 75.634s).

5.3.5 Phase 5 — Directory Enumeration (Packets #118–159, Time: 78.142–94.990s)

The attacker executed ls to enumerate files in the web server's current working directory:

```
REQUEST (Packet #122, Time: 78.142s): GET /badshell.php?cmd=ls HTTP/1.1RESPONSE (Packet #125):HTTP/1.1 200 OKContent-Length: 137UNCOMPRESSED BODY:<!-- Simple PHP backdoor by DK (http://michaeldaw.org) --><pre>badshell.phpindex.htmlindex.html~index2.html.reverse_shell.phpsecret.txt</pre>
```

The directory listing returned six files. The presence of `.reverse_shell.php` is an extremely significant finding; this is a second, hidden backdoor planted alongside badshell.php. The dot prefix causes the file to be hidden from standard directory listings on Linux, but it appeared here because the webshell executed ls in the web root without the -a flag which still showed the file. A reverse shell PHP script, when triggered, initiates an outbound TCP connection from the compromised server back to the attacker, establishing an interactive shell session that bypasses inbound firewall rules. This represents a more sophisticated and persistent access mechanism than the webshell alone. The ls command was repeated at packet #144 (Time: 87.322s).

5.3.6 Phase 6 — Data Exfiltration (Packets # 156–171, Time: 94.991s)

The final and most critical phase of the attack involved the targeted exfiltration of the secret.txt file, which was directly identified in the previous ls output:

REQUEST (Packet #160, Time: 94.991s): GET /badshell.php?cmd=cat%20secret.txt HTTP/1.1Host: 192.168.56.102(Note: %20 is URL-encoded space character)**RESPONSE (Packet #163, Time: 94.995s):**HTTP/1.1 200 OKServer: Apache/2.4.7 (Ubuntu)X-Powered-By: PHP/5.5.9-1ubuntu4.14Content-Length: 131UNCOMPRESSED BODY:<!-- Simple PHP backdoor by DK (http://michaeldaw.org) --><pre>This should not be accessible to the outside world!</pre>

The server successfully executed the cat secret.txt command and returned the file's contents to the attacker in a HTTP 200 OK response. The file contents 'This should not be accessible to the outside world!' which confirms that the file was intentionally designated as sensitive and restricted. The attacker received this content within 4 milliseconds of sending the request (94.991s request, 94.995s response), confirming immediate successful exfiltration. This constitutes a confirmed data breach of a file explicitly marked as confidential internal information.

5.4 Persistence Mechanisms Identified

The directory listing at packet #125 revealed two distinct persistence mechanisms planted on the GTTA server, both attributable to the initial compromise documented in Case GTTA-DFIR-2025-001:

Backdoor	File	Type	Capability	Discovery Method
Primary Webshell	badshell.php	PHP Webshell — Simple PHP Backdoor by DK (michaeldaw.org, 2006)	Execute OS commands via HTTP GET requests, return output to browser	Direct HTTP access — GET /badshell.php
Hidden Reverse Shell	.reverse_shell.php	PHP Reverse Shell — hidden file (dot prefix)	Initiate outbound TCP connection to attacker, establish interactive shell bypassing inbound firewall rules	Directory listing via webshell ls command

The presence of two separate backdoors indicates the attacker followed a deliberate persistence strategy: the webshell (badshell.php) provides a stable, browser-accessible command execution interface, while the hidden reverse shell (.reverse_shell.php) provides a more powerful interactive shell capability that can be activated on demand. Neither file belongs to a legitimate web application and both must be treated as confirmed malicious implants.

5.5 Linkage to Case GTTA-DFIR-2025-001

This investigation is inseparable from Case GTTA-DFIR-2025-001. The following evidence establishes a direct causal chain between the two incidents, as seen in the table below:

Evidence	PCAP 1 (Dec 31, 2025)	PCAP 2 (Mar 14, 2026)
Initial Access	CVE-2024-4577 exploitation — PHP-CGI injection — 200 OK confirmed	Not applicable — access already established

Evidence	PCAP 1 (Dec 31, 2025)	PCAP 2 (Mar 14, 2026)
Webshell	Planted via CVE-2024-4577 payload (cve_2024_4577.selfrep worm)	badshell.php confirmed active and operational
Server	Apache/2.4.65 (Debian) at 203.161.44.208 (perimeter)	Apache/2.4.7 (Ubuntu) at 192.168.56.102 (internal)
Attacker Tool	libredtail-http automated framework	Manual browser-based interaction (Safari UA)
Gap Between Incidents	N/A	Approximately 10 weeks after initial compromise
Attacker Position	External internet attacker	Internal network attacker — confirms lateral movement

The migration of the attacker from an external internet-facing position (PCAP 1) to an internal network position (PCAP 2) is the most critical cross-case finding. In PCAP 1, all traffic originated from external IP addresses. In PCAP 2, the attacker is operating from 192.168.56.1 on the internal 192.168.56.0/24 subnet, demonstrating confirmed lateral movement from the compromised perimeter into the GTTA internal network over the intervening 10-week period.

6. Timeline of Events

All timestamps are relative to the start of the PCAP capture on March 14, 2026. Server-reported timestamps from HTTP response headers are noted where available, though the server clock (reporting April 2016) is not reliable for absolute dating and is noted for completeness only, as recorded in the below table;

Packet #	Relative Time	Server Clock	Event	Severity
1	0.000s	—	TCP SYN — Attacker (192.168.56.1) initiates connection to victim (192.168.56.102:80)	INFO
2-4	0.000–0.000s	—	TCP three-way handshake completed — connection established	INFO
5	0.000s	—	GET / HTTP/1.1 — Server reconnaissance begins	MEDIUM
9	0.001s	02:55:07	HTTP/1.1 200 OK — Apache/2.4.7 Ubuntu server fingerprinted	MEDIUM
13	0.014s	—	GET /icons/ubuntu-logo.png — Default Ubuntu Apache page confirmed	LOW
14	0.014s	02:55:07	HTTP/1.1 304 Not Modified — Server confirmed Ubuntu	INFO
27	26.534s	—	GET /badshell.php — Webshell directly accessed	CRITICAL

Packet #	Relative Time	Server Clock	Event	Severity
30	26.624s	02:55:34	HTTP/1.1 200 OK — Webshell confirmed: Simple PHP Backdoor by DK	CRITICAL
46	45.124s	—	GET /badshell.php?/cmd=whoami — First command attempt (syntax error)	HIGH
49	45.125s	02:55:52	HTTP/1.1 200 OK — Webshell page returned, no command output (wrong syntax)	HIGH
62	54.512s	—	GET /badshell.php?cmd=whoami — Corrected syntax, command executed	CRITICAL
65	54.522s	02:56:02	HTTP/1.1 200 OK — Response: www-data (Apache service account confirmed)	CRITICAL
78	60.397s	—	GET /badshell.php?cmd=whoami — Command repeated for verification	HIGH
81	60.410s	02:56:08	HTTP/1.1 200 OK — Response: www-data (confirmed)	HIGH
90	63.745s	—	GET /badshell.php?cmd=finger — User enumeration executed	CRITICAL
93	63.756s	02:56:11	HTTP/1.1 200 OK — Response: ubuntu logged in via pts/0 (:0) since Apr 5 22:50	CRITICAL
112	75.634s	—	GET /badshell.php?cmd=finger — User enumeration repeated	HIGH
115	75.638s	02:56:23	HTTP/1.1 200 OK — Same ubuntu user session confirmed	HIGH
122	78.142s	—	GET /badshell.php?cmd=ls — Directory enumeration executed	CRITICAL
125	78.146s	02:56:26	HTTP/1.1 200 OK — Directory listing: badshell.php, .reverse_shell.php, secret.txt revealed	CRITICAL
144	87.322s	—	GET /badshell.php?cmd=ls — Directory listing repeated	HIGH
147	87.325s	02:56:35	HTTP/1.1 200 OK — Same directory contents confirmed	HIGH
160	94.991s	—	GET /badshell.php?cmd=cat%20secret.txt — Data exfiltration initiated	CRITICAL
163	94.995s	02:56:42	HTTP/1.1 200 OK — secret.txt exfiltrated: 'This should not be accessible to the outside world!'	CRITICAL
164–171	94.996s+	—	TCP FIN/ACK — Session terminated gracefully by server	INFO

7. Remediation and Recommendations

7.1 Immediate Actions (Critical — Within 24 Hours)

- **Isolate 192.168.56.102:** Immediately take the compromised server offline or isolate it from the network pending full forensic examination. Do not attempt to clean the system in place — a full rebuild is required.
- **Remove Webshells:** Identify and delete badshell.php and .reverse_shell.php from the web root. Assume additional webshells may be present in locations not captured in this session and conduct a full scan of all web-accessible directories.
- **Search for Additional Implants:** Conduct a comprehensive file system audit for any other files with recent modification timestamps, unexpected PHP files, or files with dot-prefix names in web directories.
- **Audit Internal Network:** The attacker's presence on 192.168.56.1 confirms lateral movement into the GTTA internal network. Immediately audit all systems on the 192.168.56.0/24 subnet for signs of compromise.
- **Rotate All Credentials:** All credentials accessible to the www-data account and the ubuntu account must be considered compromised and rotated immediately.
- **Preserve Evidence:** Before any remediation, create forensic images of the compromised server's disk and memory for full investigation.

7.2 Short-Term Remediation (Within 7 Days)

- **Rebuild the Server:** Due to the confirmed presence of two backdoors and the likelihood of additional undiscovered implants, the compromised server at 192.168.56.102 must be completely rebuilt from a clean image rather than cleaned in place.
- **Upgrade Server Software:** The rebuilt server must run current, supported software versions. Apache/2.4.7 and PHP/5.5.9 are both severely end-of-life. Deploy current stable versions with all security patches applied.
- **File Integrity Monitoring:** Implement a file integrity monitoring solution (e.g., AIDE, Tripwire) on all web servers to detect unauthorised file creation or modification in real time.
- **Web Application Firewall:** Deploy a WAF to detect and block webshell access patterns including requests with OS command parameters such as cmd=, exec=, and system=.
- **Restrict PHP Execution:** Disable PHP execution in web directories where it is not required. Implement open_basedir restrictions to prevent PHP scripts from accessing files outside the web root.
- **Remove Sensitive Files from Web Root:** Files such as secret.txt must never reside in a web-accessible directory. Sensitive data must be stored outside the document root with appropriate access controls.

7.3 Strategic Recommendations

- **Network Segmentation Review:** The attacker's presence on the internal 192.168.56.0/24 subnet indicates the perimeter compromise from December 2025 resulted in lateral movement. Conduct a full network segmentation review to identify and close pathways between the DMZ and internal networks.
- **Incident Response Plan:** Activate a formal incident response process. This is not an isolated event but rather the second documented attack in a campaign that began December 31, 2025. A comprehensive IR investigation of all GTTA systems is required.
- **Threat Hunting:** Conduct proactive threat hunting across the GTTA environment for indicators of compromise from Case GTTA-DFIR-2025-001 including the C2 server 178.16.55.224, the domain wiresharkworkshop.online, and the User-Agent string libredtail-http.
- **Patch Management:** The presence of Apache/2.4.7 and PHP/5.5.9 both over a decade out of support indicates a systemic patch management failure. Implement a formal vulnerability management programme with defined remediation SLAs.
- **Security Monitoring:** Deploy network intrusion detection (IDS/IPS) and SIEM capabilities to detect webshell activity, internal lateral movement, and data exfiltration in real time rather than through retrospective PCAP analysis.

8. Conclusion and Forensic Opinion

Based on the complete analysis of 2026-03-14 perimeter.pcap, it is clearly established that the GTTA internal server at 192.168.56.102 was actively exploited on March 14, 2026, by a threat actor operating from an internal network position at 192.168.56.1 using a Kali Linux attack platform.

The attack was conducted manually via a PHP webshell the Simple PHP Backdoor by DK (badshell.php) that was planted on the server during the confirmed CVE-2024-4577 compromise documented in Case GTTA-DFIR-2025-001 on December 31, 2025. The attacker executed four commands in sequence namely, **whoami**, **finger**, **ls**, and **cat secret.txt**. All four commands executed successfully and returned output to the attacker. The final command constitutes a confirmed exfiltration of a file explicitly labelled as sensitive.

Also, the directory listing revealed a second, hidden backdoor (.reverse_shell.php) indicating the attacker has deeper persistence capabilities than the webshell alone. The attacker's presence on the internal GTTA network confirms that lateral movement occurred between the initial perimeter compromise in December 2025 and this follow-on session in March 2026.

Taken together, both Cases GTTA-DFIR-2025-001 and GTTA-DFIR-2026-002 confirms a complete, multi-stage intrusion campaign against GTTA infrastructure with an initial exploitation of a perimeter web server via a critical PHP vulnerability, deployment of persistent backdoors, establishment of internal network access, and confirmed exfiltration of sensitive data. The campaign remains active, meaning the

presence of an unactivated reverse shell indicates the attacker retains additional exploitation capability that has not yet been fully exercised.

FORENSIC OPINION: The GTTA internal server at 192.168.56.102 was actively compromised and used as a data exfiltration platform on March 14, 2026. Two backdoors are confirmed present. Sensitive file contents were successfully exfiltrated. The attacker has established a persistent internal foothold within the GTTA network. This incident is the direct continuation of the December 31, 2025 perimeter intrusion. Immediate isolation, forensic preservation, and full environment-wide investigation are required.

9. Appendices

Appendix A — Indicators of Compromise (IOC) Summary

IOC Type	Value	Description
IP Address	192.168.56.1	Attacker — Kali Linux internal host — source of all malicious requests
IP Address	192.168.56.102	Victim — Ubuntu server — Apache/2.4.7, PHP/5.5.9
File	badshell.php	PHP webshell — Simple PHP Backdoor by DK — planted in web root
File	.reverse_shell.php	Hidden PHP reverse shell — second persistence mechanism — planted in web root
File	secret.txt	Exfiltrated file — contents: 'This should not be accessible to the outside world!'
User-Agent	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_4) AppleWebKit/601.5.17	Attacker browser UA — Safari on Mac OS X El Capitan
Server	Apache/2.4.7 (Ubuntu)	Victim server software — severely outdated, end-of-life
Server	PHP/5.5.9-1ubuntu4.14	Victim PHP version — end-of-life since July 2016
MAC Address	08:00:27:be:9f:30	Victim server NIC — VirtualBox vendor prefix

Appendix B — Webshell Command Execution Log

Complete record of all commands executed via badshell.php with server responses:

Seq	Req Packet	Resp Packet	Relative Time	Command	HTTP Status	Server Response
1	#27	#30	26.534s	GET /badshell.php (no command)	200 OK	Webshell page with usage instructions
2	#46	#49	45.124s	GET /badshell.php?cmd=whoami (syntax error)	200 OK	Webshell page only — no command output (wrong syntax)
3	#62	#65	54.512s	GET /badshell.php?cmd=whoami	200 OK	www-data
4	#78	#81	60.397s	GET /badshell.php?cmd=whoami (repeated)	200 OK	www-data
5	#90	#93	63.745s	GET /badshell.php?cmd=finger	200 OK	Login: ubuntu, Name: ubuntu, Tty: pts/0, Login Time: Apr 5 22:50, Office: (:0)
6	#112	#115	75.634s	GET /badshell.php?cmd=finger (repeated)	200 OK	Same output as above
7	#122	#125	78.142s	GET /badshell.php?cmd=ls	200 OK	badshell.php, index.html, index.html~, index2.html, .reverse_shell.php, secret.txt
8	#144	#147	87.322s	GET /badshell.php?cmd=ls (repeated)	200 OK	Same directory listing as above
9	#160	#163	94.991s	GET /badshell.php?cmd=cat %20secret.txt	200 OK	This should not be accessible to the outside world!

Appendix C — Cross-Case Attack Chain Summary

Date	Case	Event	Technique	MITRE ATT&CK
Dec 31, 2025	GTТА-DFIR-202 5-001	CVE-2024-4577 PHP-CGI RCE exploited on 203.161.44.208	Exploit Public-Facing Application	T1190
Dec 31, 2025	GTТА-DFIR-202 5-001	Self-replicating worm deployed from C2 178.16.55.224	Ingress Tool Transfer	T1105
Dec 31, 2025	GTТА-DFIR-202 5-001	badshell.php and .reverse_shell.php planted on server	Server Software Component: Web Shell	T1505.003
Dec 31, 2025 – Mar 14, 2026	Between cases	Lateral movement from perimeter to internal network	Internal Spearphishing / Lateral Tool Transfer	T1534
Mar 14, 2026	GTТА-DFIR-202 6-002	Attacker returns from internal position (192.168.56.1)	Use Alternate Authentication Material	T1550
Mar 14, 2026	GTТА-DFIR-202 6-002	whoami executed — www-data confirmed	System Owner/User Discovery	T1033
Mar 14, 2026	GTТА-DFIR-202 6-002	finger executed — ubuntu user enumerated	Account Discovery: Local Account	T1087.001
Mar 14, 2026	GTТА-DFIR-202 6-002	ls executed — .reverse_shell.php and secret.txt discovered	File and Directory Discovery	T1083
Mar 14, 2026	GTТА-DFIR-202 6-002	cat secret.txt — sensitive file exfiltrated	Data from Local System	T1005
Mar 14, 2026	GTТА-DFIR-202 6-002	Data transmitted to attacker via HTTP response	Exfiltration Over C2 Channel	T1041

Appendix D — Server Software Vulnerability Summary

Software	Version Found	End-of-Life Date	Known Critical CVEs	Recommended Action
Apache HTTP Server	2.4.7	Supported (but extremely outdated)	CVE-2021-41773, CVE-2021-42013, CVE-2017-7679	Upgrade to current stable release
PHP	5.5.9-1ubuntu4.14	July 10, 2016	CVE-2019-11043, CVE-2018-7584, multiple RCE CVEs	Upgrade to PHP 8.2 or later
Ubuntu	Ubuntu (version inferred from packages)	Inferred legacy LTS	Numerous kernel and package CVEs	Rebuild with current Ubuntu LTS

